

FIND SIMILAR JOURNALS ?

options

About this article



Cite this article

Rea-Guaman, A.M., Mejia, J., San Feliu, T. et al. AVARCIBER: a framework for assessing cybersecurity risks. *Cluster Comput* 23, 1827–1843 (2020).
<https://doi.org/10.1007/s10586-019-03034-9>

[Download citation](#)

Received	Revised	Accepted
24 September 2019	01 November 2019	19 December 2019

Published	Issue Date
01 January 2020	September 2020

DOI
<https://doi.org/10.1007/s10586-019-03034-9>

Keywords

Cybersecurity framework
 Cybersecurity vulnerabilities
 Cybersecurity threats

Instant access to the full article PDF.

Rent this article via [DeepDyve](#)

[Institutional subscriptions](#)

Sections

Figures

References

[Abstract](#)

[References](#)

[Author information](#)

[Additional information](#)

[Rights and permissions](#)

[About this article](#)

Advertisement

SPRINGER NATURE springernature.com

Explore the Synthesis Collection of Technology
 Short, focused books publishing

A VARCIBER: a framework for assessing cybersecurity risks

Angel Marcelo Rea-Guaman, Jezreel Mejía, Tomas San Feliu & Jose A. Calvo-Manzano

Cluster Computing

The Journal of Networks, Software Tools
and Applications

ISSN 1386-7857

Cluster Comput

DOI 10.1007/s10586-019-03034-9



Your article is protected by copyright and all rights are held exclusively by Springer Science+Business Media, LLC, part of Springer Nature. This e-offprint is for personal use only and shall not be self-archived in electronic repositories. If you wish to self-archive your article, please use the accepted manuscript version for posting on your own website. You may further deposit the accepted manuscript version in any repository, provided it is only made publicly available 12 months after official publication or later and provided acknowledgement is given to the original source of publication and a link is inserted to the published article on Springer's website. The link must be accompanied by the following text: "The final publication is available at link.springer.com".



AVARCIBER: a framework for assessing cybersecurity risks

Angel Marcelo Rea-Guaman¹ · Jezreel Mejía² · Tomas San Feliu¹ · Jose A. Calvo-Manzano¹

Received: 24 September 2019 / Revised: 1 November 2019 / Accepted: 19 December 2019
© Springer Science+Business Media, LLC, part of Springer Nature 2020

Abstract

The identification and assessment of risks are a fundamental part of cybersecurity. Determining the elements that participate in this field is difficult because there is no exclusive approach to cybersecurity. This document aims to provide a framework to identify and assess cybersecurity risks. For this, a systematic review of the studies related to cybersecurity risk taxonomies was carried out. The main elements of the proposed conceptual model and framework have been determined by applying the snowball technique. To validate the implementation of the proposed framework, a case study has been implemented at the Ecuadorian Social Security Institute. The first task was to consolidate the information in a baseline. Once the baseline was obtained, the defined framework has been applied. As a result, through the use of the proposed framework, the assessment process has improved the decision-making process regarding the importance and criticality of the risks and countermeasures that must be applied.

Keywords Cybersecurity framework · Cybersecurity vulnerabilities · Cybersecurity threats

1 Introduction

Cybersecurity is a widely used term that deals with the security of information systems and data, but it has many different definitions. According to the ESET security community [1], cybersecurity is defined as “protection of information assets, through the treatment of threats that put at risk the information that is processed, stored and transported by the interconnected information systems”. Therefore, it is a discipline that involves technology, people, information, and processes to allow risk-free operations.

In this context, the interest in cybersecurity issues is increasing [2–4]. Almost every week or every day, you hear about the violation of cybersecurity or a similar incident. The most common incidents are usually: personal information compromised, stolen credit cards, lost medical records, unauthorized access and theft of business information, and attacks on critical systems, among others.

In recent years, these incidents have been published in press headlines, and the impact of intrusions on information systems is detailed, such as, for example [5]:

- In September 2018. British Airways (BA)—380,000 affected customers. On its website, BA said that the stolen data included personal and financial details of customers who make reservations and changes on ba.com and the airline’s application.
- In 2018. Facebook—50 million compromised accounts. Facebook announced that a vulnerability embedded in the “See as” feature allows strangers to steal authentication tokens from 50 million users. Personal data affected by hacking was extended to private publications, conversations, records, images sent by chat, and much more.
- In November 2018. Marriot—500 million records. At the end of November, the world’s largest hotel chain discovered that it had been the goal of a sophisticated

✉ Jezreel Mejía
jmejia@cimat.mx

Angel Marcelo Rea-Guaman
marcelo.rea.guaman@alumnos.upm.es

Tomas San Feliu
tomas.sanfeliu@upm.es

Jose A. Calvo-Manzano
joseantonio.calvomanzano@upm.es

¹ School of Computer Engineering, Universidad Politécnica de Madrid, Madrid, Spain

² Centro de Investigación en Matemáticas A.C., Zacatecas, Mexico

operation in which hackers extracted personal and financial data from half a billion customers over 4 years.

Currently, laws are punishing such crimes with increasing severity. In 2019, companies must be smart to consolidate their security posture and avoid hefty fines and irreparable damage to their image. One way to start addressing cybersecurity would be to analyze the situation in which the organization is in this area, through the implementation of maturity models related to cybersecurity.

The way organizations address cybersecurity capacity is essential for effective, efficient, and sustainable cybersecurity. In order organizations can improve their cybersecurity capabilities, industry and the technical community have developed cybersecurity maturity models that measure cybersecurity capabilities and position them at different levels for continuous improvement, due to change is continuous in terms of threats, vulnerabilities, risks, strategy, and organizational needs.

Therefore, the maturity levels vary from an initial level, where an organization may have just begun to consider cybersecurity, to a dynamic scenario, where an organization can adapt quickly to changes in the cybersecurity environment.

The cybersecurity maturity models provide a benchmark to assess the current level of capacity of the practices, processes, and methods that organizations have implemented in terms of cybersecurity. There are several maturity models that industry uses for assessing the maturity levels. The main maturity models named in studies of scientific journals according to the systematic review [6] are: the Cybersecurity Capability Maturity Model (C2M2) [7], the National Initiative for Cybersecurity Education (NICE) [8], the Systems Security Engineering Capability Maturity Model (SSE-CMM) [9], and the Community Cyber Security Maturity Model (CCSM) [10].

All these maturity models most named in the scientific papers identify cybersecurity risk management as a fundamental element in the initial level of maturity. Risk management is a cornerstone of proper governance guidelines [ISO 38500] [11], both in the public and private sectors, where it is considered a fundamental principle that government decisions are based on knowledge of involved risks. The main literature on cybersecurity risks [2, 12–14] agrees that assets, cybersecurity vulnerabilities and threats should be identified as fundamental elements. Even, there are entire books dedicated to risk management, although the focus on cybersecurity is still incipient [2, 15–19].

The fundamental knowledge of these elements has been defined through conceptual models [15, 20–23]. These

conceptual models relate these fundamental elements, however each model does so according to its particular approach, for example, some of them are focused on the cloud computing (see Sect. 2). Therefore, a framework for assessing risks based on the conceptual models has been defined in this paper, which is focused on cybersecurity.

This article is organized as follows: Sect. 2 introduces the context of cybersecurity conceptual models; Sect. 3 gives the details of the proposed framework. Section 4 reports the results obtained in a case study carried out based on the proposed framework, and the results obtained are compared with the company's old way of working (called the baseline). And finally, Sect. 5 presents the conclusions that have been identified and future research lines.

2 Context

Considering that cybersecurity risks are the starting point of all cybersecurity maturity models, a systematic review (SR) regarding cybersecurity risk taxonomies was carried out [24]. In this SR, it was found that some articles [12–14] identify international standards as references, such as the standards of the National Institute of Standards and Technology (NIST) [15]. These articles identify the main elements, indicated above, involved in the cybersecurity risk management. To perform the analysis of the articles identified in the SR, the snowball technique [25] was used in order to identify the elements that should be considered in a conceptual model of cybersecurity risk management, independently of its approach and use.

From the snowball technique [25] applied to the articles obtained by the systematic review [24], the main elements of the conceptual model of cybersecurity risk management and their relationships have been determined. This information has served as the basis for the design of the proposed conceptual model. The documents considered have been: [20], focused on the relationship of terms, and security ontologies; [21], focused on risk entities and its relationships; [22], focused on risk entities and its relationships; [15], focused on the main risk factors; and [23], focused on cybersecurity information.

In addition, continuing with the application of the snowball technique [25] to the conceptual models indicated in the previous articles, the following conceptual models of ontologies and taxonomies have been considered for this proposal: [26], focused on asset ontologies per user; [27], focused on asset ontologies; [28], paper focused on taxonomy of impacts on assets; [29], focused on mobile asset taxonomy; [30], focused on threat taxonomy; [31], focused on taxonomy of voice over IP threats; [32], focused on attack ontology; [33], focused on attack taxonomy; [34],

focused on vulnerability taxonomy; [35], focused on vulnerability taxonomy based on information attributes; [36], paper focused on vulnerability taxonomy; and [37], focused on vulnerability taxonomy.

From the analysis made to the previous articles, the following particularities have been identified:

- Conceptual models have different approaches according to specific needs, although they identify the elements of cybersecurity risk management.
- The critical elements that should be considered in cybersecurity risk management are: the organization's assets, the cybersecurity vulnerabilities of the assets, and the cybersecurity threats that materialize the cybersecurity vulnerabilities, generating the cybersecurity risks.
- There are countermeasures that help mitigate the impact of risks. Some countermeasures do so against threats and others against vulnerabilities.
- The participation of the security dimensions (confidentiality, availability, and integrity) as part of the elements of the conceptual models of cybersecurity risk management is not shown.
- An analysis related to the vulnerabilities of the assets based on security dimensions is not found.

As a result of this analysis, it has been determined that there is no common framework for cybersecurity because the conceptual models identified are based on particular approaches, and use different semantics for the relationships of the main elements of cybersecurity risks (assets, vulnerabilities, threats, and risks).

For this reason, for the cybersecurity framework proposed in this paper and based on the conceptual risk models, it is necessary to establish a conceptual model that establishes the relationships of the elements found in cybersecurity risk management.

Next, the activities carried out to establish the proposed conceptual model are:

- Identify the entities that participate in cybersecurity risk management based on the main elements above.
- Establish the relationships between each of the entities identified.
- Determine the cardinality between the entities identified.

Then, a diagram has been made with the concepts and relationships of the identified entities, which is shown in Fig. 1. The grey entities are a result of applying the snowball technique. The rest of the entities (white) were included to complement the conceptual model of cybersecurity risk management. The relationships between the elements have been generated considering the cybersecurity approach, and obtaining the following added value:

- From the relationship of the *asset* with *vulnerability*, it is important to note that the entity *assessment dimension* describes the characteristics that can be measured in the vulnerabilities. The most common characteristics are availability, integrity, and confidentiality, although criticality, authenticity or traceability could also be included.
- Another important relationship of this conceptual model is that *countermeasures* are directly related to the cybersecurity vulnerabilities of assets.

3 AVARCIBER: a framework for identifying and assessing cybersecurity risks

The conceptual model defined in the previous section serves as the basis for the definition of a framework, named AVARCIBER by its Spanish Acronym (Assets, Vulnerabilities, Threats, Risks of Cybersecurity). ISO 27005 contains guidelines for the risk management process; therefore, parameters of ISO 27005 [16] have been used as a reference, extending specific parameters that we will indicate below. The implementation of a framework for cybersecurity risk management must follow a series of steps (activities and tasks) to be effective and adequately fulfill its function. The activities that should be followed in the implementation of the framework are described in detail below.

3.1 AVARCIBER activities

For the implementation of the framework, it is necessary to perform the six main activities described below.

3.1.1 Activity 1: launch

The framework makes extensive use of taxonomies as an element to help identify risks. Taxonomies represent the prior knowledge that the organization has regarding the types of assets to be protected, and also the type of vulnerabilities and threats to focus the efforts of the organization. Therefore, in this launching activity, the taxonomies corresponding to assets, cybersecurity vulnerabilities, and cybersecurity threats are established and/or updated. The organization must be aware of the importance of establishing and maintaining updated taxonomies to address the ever-changing cybersecurity environment.

An organization could adopt an industry taxonomy as a basis for generating its own taxonomies. The tasks to be performed in this activity are the following:

- Task 1: establish the taxonomy of assets (based, for example, on the standard ISO 27005 [16]).

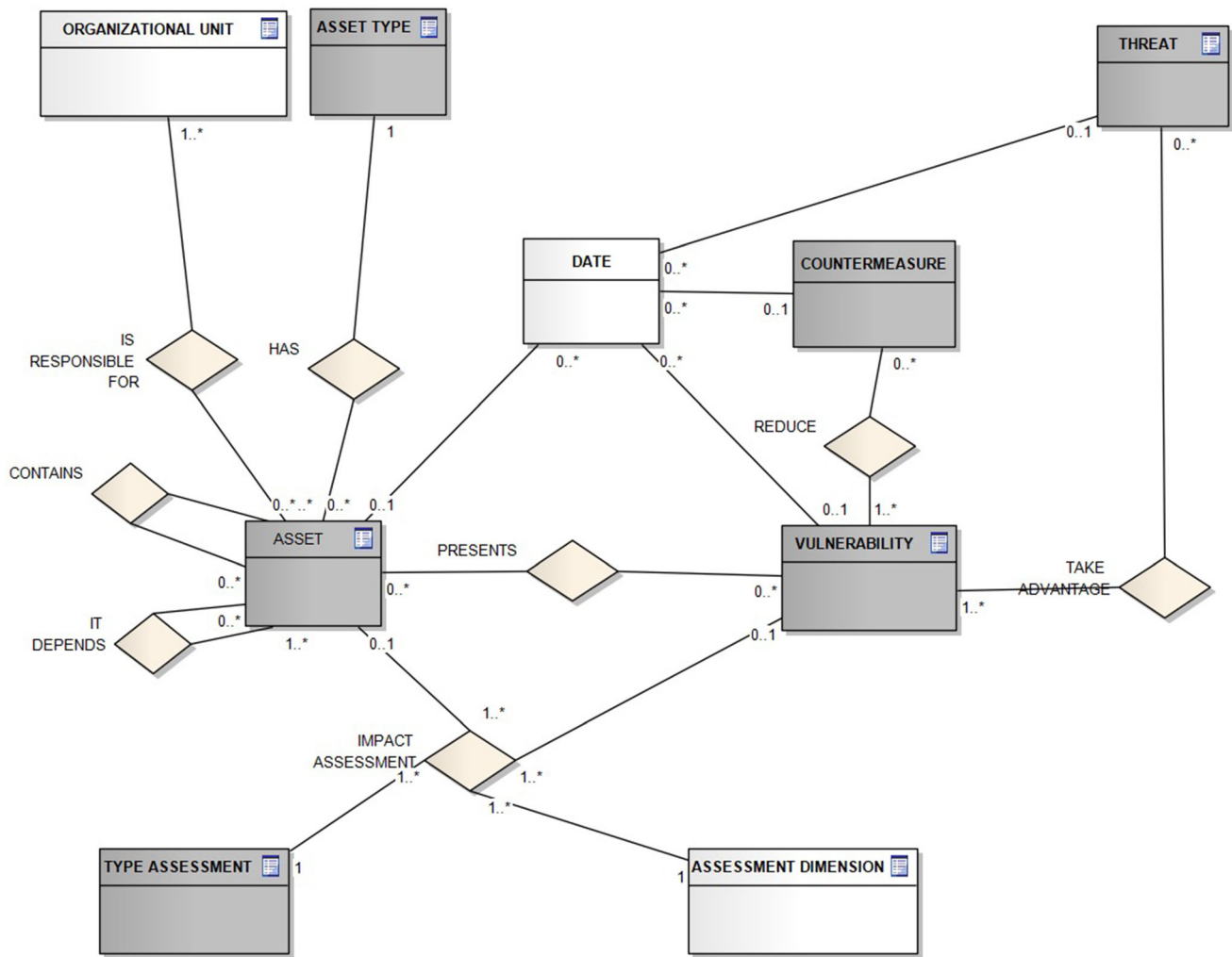


Fig. 1 Conceptual model for identifying and assessing cybersecurity risks

- Task 2: establish the taxonomy of cybersecurity vulnerabilities (based, for example, on the standard ISO 27005 [16]).
- Task 3: establish the taxonomy of cybersecurity threats (based, for example, on ENISA 2018 [38]).

3.1.2 Activity 2: identify and assess assets

This activity refers to the effort that every organization must make to start raising awareness about cybersecurity among all members of the organization. One of the initial questions to ask is: what do we want to protect? Therefore, in this activity an analysis of the elements that are most important for the organization is made, taking into consideration the following questions: What activity do we do? What is most important for the organization? What are the institutional objectives? What services do I provide?

The tasks to be performed in this activity are the following:

- Task 1: assets are selected from the taxonomy previously established in the previous activity (Activity 1 – Task 1) or are identified by the organization.
- Task 2: the organization identifies the security dimensions (commonly integrity, confidentiality, and availability) for the assets, and measures the impact of the asset. The assessment of the impact value related to the asset is based on ISO 27005 [16] (see Table 1).
- Task 3: the criticality of the asset is done by taking the highest value of the impact of the asset from the security dimensions calculated in Task 2. An example of the above is shown in Table 2.

3.1.3 Activity 3: assess the damage level for the vulnerability-asset (dimension) tuples

In this activity, the damage level related to the cybersecurity vulnerabilities of the assets of the organization must be determined. The assessment of the vulnerability damage

Table 1 Assessment of the impact value related to the asset based on ISO 27005

Damage level	Description	Impact value
High	Information whose permanent inaccessibility for one hour could prevent the execution of the organization's activities	8–10
Medium	Information whose permanent inaccessibility during the working day could prevent the execution of the organization's activities	5–7
Low	Information whose permanent inaccessibility for a week could cause significant damage to the organization	2–4
Null	Information whose inaccessibility does not affect the regular activity of the organization	0–1

Table 2 Assessment of the asset and its security dimensions

Asset	Dimension	Impact value
Asset 1	Confidentiality	1
Asset 1	Integrity	3
Asset 1	Availability	8
Asset 1	Criticality	8 (max (1,3,8))

level is carried out based on the values showed in Table 3 and established by the organization. The values proposed in Table 3 have been obtained from ISO 27005 [16], adding the damage level of “extreme damage”, “very high” and “negligible”. These three damage levels allow us to have a better accuracy at the time of assigning the damage level of the vulnerability. The organization must determine the value of the damage level related to the vulnerability for each dimension (confidentiality, availability, integrity, and, also, criticality) of the asset. The assessment of the vulnerability damage level is done by defining the importance and impact in the event that the damage to the asset is beyond repair.

For example, if it is estimated that the damage that could occur in the asset due to the linked vulnerability is “high”, then the assigned damage level related to the tuple vulnerability—asset(dimension) would be between 6 and 8.

Table 3 Quantification of damage level related to cybersecurity vulnerability

Damage level	Lower value	Upper value
Extreme damage	10	10
Very high	9	9
High	6	8
Medium	3	5
Low	1	2
Negligible	0	0

The tasks to be performed in this activity are the following:

- Task 1: assign cybersecurity vulnerabilities to each asset from those identified in the previously established vulnerability taxonomy.
- Task 2: evaluate the damage level for each vulnerability-asset (dimension) tuple. The assessment will be carried out for each security dimension (including criticality), considering the damage levels defined in Table 3. An example of the assessment of the damage levels of vulnerability on the asset for each dimension is shown in Table 4.
- Task 3: accumulate the damage values for each vulnerability-asset tuple, regardless of its dimension. In the example, the total damage value of the vulnerability-asset tuple “Vulnerability 1 – Asset 1” would be equal to 20 (1+3+8+8).
- Task 4: obtain the average damage value of the vulnerability-asset tuple. In the example, the *average damage value* of the vulnerability-asset tuple “Vulnerability 1 – Asset 1” would be 5 (20 divided by 4 dimensions considered) (see Table 5, *Average Damage Value* column).
- Task 5: repeat tasks 2, 3, and 4 for all vulnerability-asset tuples.
- Task 6: assign a monetary value to each vulnerability-asset (dimension) tuples that are affecting the assets of the organization. This value is called the *Damage Cost*. The damage cost is a function of both the market price of the asset, as well as the expected damage, and its replacement (see *Damage Cost* column in Table 5).
- Task 7: assign a monetary cost to each asset. The organization determines this cost for the asset in case it had loss or damage, according to the commercial value and the cost of replacing it (see *Asset Cost* column in Table 5).

Table 4 Damage level of the vulnerability-asset (dimension) tuples

Vulnerability	Asset	Dimensions/damage level			
		Confidentiality	Integrity	Availability	Criticality
Vulnerability 1	Asset 1	1	3	8	8
Vulnerability 2	Asset 1	2	4	5	8
Vulnerability 3	Asset 1	6	6	7	8
Vulnerability 1	Asset 2	6	8	10	7
Vulnerability 2	Asset 2	10	7	10	7
Vulnerability 3	Asset 2	7	8	9	7

Table 5 Average damage value and damage cost for each vulnerability-asset (dimension) tuple, and Asset Cost

Vulnerability	Asset	Asset cost	Dimensions/damage level				Average damage value	Damage cost
			Confidentiality	Integrity	Availability	Criticality		
Vulnerability 1	Asset 1	1000€	1	3	8	8	5	600€
Vulnerability 2	Asset 1		2	4	5	8	4.75	350€
Vulnerability 3	Asset 1		6	6	7	8	6.75	700€
Vulnerability 1	Asset 2	800€	6	8	10	7	7.75	400€
Vulnerability 2	Asset 2		10	7	10	7	8.5	500€
Vulnerability 3	Asset 2		7	8	9	7	7.75	350€

Table 6 Threats and Vulnerabilities with average damage value and damage cost

Threat	Vulnerability	Asset	Asset cost	Average damage value	Damage cost
Threat 1	Vulnerability 1	Asset 1	1000€	5	600€
Threat 1	Vulnerability 2	Asset 1		4.75	350€
Threat 2	Vulnerability 3	Asset 1		6.75	700€
Threat 2	Vulnerability 1	Asset 2	800€	7.75	400€
Threat 2	Vulnerability 2	Asset 2		8.5	500€
Threat 1	Vulnerability 3	Asset 2		7.75	350€

3.1.4 Activity 4: identify cybersecurity threats

In this activity, cybersecurity threats that can affect the organization, and may materialize the cybersecurity vulnerabilities in the assets are identified. To do this, it is necessary to: (1) relate the cybersecurity threats with the existing vulnerabilities, (2) calculate the average damage value of the cybersecurity vulnerabilities associated with the threat, and (3) calculate the total cost of the damage of the cybersecurity vulnerabilities associated with the threat.

The tasks to be performed in this activity are the following:

- Task 1: identify all cybersecurity threats from the taxonomy of cybersecurity threats previously established in Activity 1—Task 3.
- Task 2: determine the vulnerabilities of the organization's assets that may materialize for each cybersecurity

threat. Threats-Vulnerabilities tuples, and Threats-Vulnerabilities-Asset tuples (by the association of the previously defined relationships) are established.

- Task 3: from the previous activity, and for all the identified vulnerability-asset tuples, recover the calculated values of: average damage value, and damage cost, and assign them to the tuples Threats-Vulnerabilities-Assets, as shown in Table 6.
- Task 4: Threats are grouped, then the average damage value of the threat (called *Threat Damage Value*) is calculated with the average of the average damage values of Table 6 related to the same Threat. In the case of Threat 1, *Threat Damage Value* is $((5+4.75+7.75)/3) = 5.83$, as shown in Table 7. In the case of the *Threat Damage Cost*, the calculation is done adding the *Damage Cost* of the vulnerability-asset tuples affected by the threat that is considered. In the case of Threat 1,

Table 7 Threats with damage value and damage cost

Threat	Threat damage value	Threat damage cost
Threat 1	5.83	1300€
Threat 2	7.66	1600€

Threat Damage Cost is calculated adding $(600€ + 350€ + 350€) = 1300€$, as shown in Table 7.

3.1.5 Activity 5: measure the risk

The associated risk is the potential impact (I, impact) multiplied by the probability of occurrence of the threat (F, frequency). The potential impact is the Threat Damage Value (rounded). The organization must establish the probability of occurrence of previous threats according to the company's values. An example is shown in Table 8, taking as reference the ISO 27005 standard [16], and adding two new ranks: "very high" and "very low" to identify very imminent and also negligible probabilities of occurrence.

An example is shown in Table 9, with values that have been taken as a reference from ISO 27005 [16].

The organization could establish:

- Low risk: the risk value ranges between 0 to 3 (green color in Table 9).
- Medium risk: the risk ranges between 4 to 6, (yellow in Table 9).
- High risk: the risk ranges between 7 to 8 (orange in Table 9).
- Extreme risk: the risk ranges between 9 to 10 (red in Table 9).

This would help the organization to make decisions: for example, establish a policy of focusing on the red and orange risks.

The tasks to be performed in this activity are the following:

- Task 1: retrieve the value of the *Threat Damage Value* (the impact) for each threat (the value that was previously calculated in Activity 4 – Task 4), as well as the *Damage Cost* of the threat (the value that was previously calculated in Activity 4 – Task 4).
- Task 2: assign the probability of occurrence of the threat. For this, similar cases that have occurred in the company and the experience of the personnel in charge are taken as a reference. In this way, the frequency of occurrence is defined for each threat (see Table 8).
- Task 3: calculate the exposure to the cybersecurity risk ($\text{Risk} = \text{Impact} \times \text{Frequency}$), as defined in Table 9.

Table 8 Probability of threat occurrence

Ranks	Probability	Description	Frequency
VH (very high)	100	Very frequent	Daily
H (high)	10	Frequent	Monthly
M (medium)	1	Probable	Once a year
L (low)	1/10	Uncommon	Every several years
VL (very low)	1/100	Very rare	Centuries

3.1.6 Activity 6: perform countermeasures

The organization will establish, as an organization policy, what risks to attack based on the available information. To perform this activity, the organization must analyze each of the risks that may be most likely to be executed by taking the reading of the risk measurement and the impact in the organization, as well as the costs that could affect the organization. In this way, the organization will be able to take the necessary countermeasures.

The tasks to be performed in this activity are the following:

- Task 1: generate a countermeasure that can mitigate or eliminate potential risks. These countermeasures are focused on the cybersecurity vulnerabilities identified. Note that countermeasures can counteract one or more vulnerabilities.
- Task 2: generate controls to verify if countermeasures have come to counteract the apparent risk of a threat by materializing the vulnerabilities of the asset. The controls allow monitoring one or several countermeasures.

4 Case study

A case study was used to validate the implementation of the framework described above. The case study was carried out at the Ecuadorian Institute of Social Security (IESS by its Spanish acronym) in the city of Quito-Ecuador. The IESS is an entity whose organization and operation are based on the principles of solidarity, obligation, universality, equity, efficiency, subsidiarity, and sufficiency. It is responsible for applying the Compulsory General Insurance System that is part of the National Social Security System.

The IESS has 30,000 employees and has seven general directorates that correspond to the seven main processes of the organization. In addition, the IESS has three additional directorates where support processes are located. One of these three directorates is the National Information Technology Directorate (DNTI by its Spanish acronym), whose

Table 9 Risk assessment matrix

RISK ASSESSMENT MATRIX														
I	F	R	I	F	R	I	F	R	I	F	R	I	F	R
0	VL	0	0	L	0	0	M	0	0	H	0	0	VH	0
1	VL	0	1	L	0	1	M	1	1	H	0	1	VH	1
2	VL	0	2	L	0	2	M	1	2	H	0	2	VH	4
3	VL	0	3	L	0	3	M	1	3	H	4	3	VH	4
4	VL	0	4	L	5	4	M	5	4	H	5	4	VH	8
5	VL	0	5	L	5	5	M	5	5	H	5	5	VH	8
6	VL	0	6	L	5	6	M	5	6	H	5	6	VH	9
7	VL	0	7	L	5	7	M	6	7	H	8	7	VH	9
8	VL	0	8	L	5	8	M	6	8	H	8	8	VH	9
9	VL	0	9	L	5	9	M	6	9	H	9	9	VH	10
10	VL	0	10	L	5	10	M	6	10	H	10	10	VH	10

mission is to: provide and manage information technology services, which will ensure an efficient access control and information security for the management of the institution, aligned with the institutional mission and the current regulatory framework. The DNTI is made up of the following sub-directorates: National Subdirectorate of Information Technology Infrastructure (SNTI by its Spanish acronym), National Subdirectorate of Computer Development (SNDI by its Spanish acronym), National Subdirectorate of Architecture and Solutions (SNAS by its Spanish acronym), and National Office of Information Security (SNSI by its Spanish acronym).

SNTI is responsible for managing the installation, configuration and implementation of technology services infrastructure, according to institutional needs in order to improve the availability of technological services. Therefore, the technological equipment is in charge of the SNTI, and it is where the work of identification of assets was carried out. The Risk Identification and Assessment included: identifying, controlling, and eliminating or minimizing events that may affect IT resources.

The organization used the Spanish methodology of Analysis and Risk Management of Information Systems (MAGERIT) as a reference methodology. However, there was no initial baseline of risks, as there was no formal risk management document. Therefore, it had to be done almost from scratch. There were only isolated efforts but they were not consolidated or analyzed, so an important effort (from October 2018 to April 2019) of standardization of the existing information had to be made. Two DNTI people in charge of the IESS host platform and one of the authors

of this paper (as an external consultant) participated in this case study. Each person of the DNTI used a total of 120 h of work, and the external consultant a total of 480 effective hours of work.

Once the baseline was obtained, the AVARCIBER framework defined above has been applied. This will allow us to know the advantages/disadvantages and the possible improvements of the framework against the current way of working (called baseline).

For the case study, it was decided to establish as a work area, the IESS Host Platform. The IESS Host platform servers are a critical and important asset for the organization, since these servers execute transactions that have not yet been migrated to the Labor History System. Therefore, it is very important that there is high availability of this platform because the Labor History applications require information from the Host Platform to provide the benefits and services to the insured.

The analysis of the IESS Host Platform was carried out, initially performing the baseline and then applying AVARCIBER. The results obtained in both cases (baseline and AVARCIBER) are shown in order to compare the results.

4.1 Risk identification and analysis of the IESS host platform

The application of the activities of the AVARCIBER framework compared to the established baseline is detailed below.

4.1.1 Activity 1: launch

The organization did not have its own taxonomies related to assets, cybersecurity vulnerabilities, and cybersecurity threats.

The tasks to be performed in this activity are:

- Task 1: establish the taxonomy of assets. AVARCIBER recommends using ISO 27005 [16]. This taxonomy is focused on classifying the assets. The categories or type of assets are: hardware, software, networks, people, facilities, and organizational structure.
- Task 2: establish the taxonomy of cybersecurity vulnerabilities. AVARCIBER recommends using ISO 27005 [16]. This taxonomy is classified according to the type of asset that would be affected, as shown in Table 10.
- Task 3: establish the taxonomy of cybersecurity threats. AVARCIBER recommends using ENISA 2018 [38]. This taxonomy is classified by the impact on the organization, as shown in Table 11.

Table 10 Sample of Vulnerability Taxonomy (by asset) related to the IESS Host Platform

Vulnerability (ISO 27005)
<i>Hardware</i>
Insufficient maintenance/Faulty installation of storage media
Humidity, dust and dirt sensitivity
<i>Software</i>
Non existing or insufficient software test
Known error in software
No 'logout' when leaving the workstation
<i>People</i>
Lack of staff
Inadequate recruitment procedures
Insufficient security training

Table 11 Sample of Threat Taxonomy related to the IESS Host Platform

Threat (ENISA)
<i>Physical attack</i>
Fraud
Sabotage
Vandalism
<i>Natural disasters</i>
Earthquakes, floods, landslides, tsunamis, heavy rains, heavy snowfall, strong winds
Fire
Pollution, dust, corrosion

4.1.2 Activity 2: identify and assess assets

The assets are selected from the asset taxonomy (Activity 1—Task 1) in the case of AVARCIBER. In the case of the baseline, the assets selected in AVARCIBER were used.

The measurement of the criticality of the assets is carried out in a similar way, both in the baseline and when applying AVARCIBER.

The tasks to be performed in this activity are:

- Task 1: those assets that participate in the IESS Host platform have been selected, based on the taxonomy assets. The *Asset* column in Table 12 shows the selected cybersecurity assets.
- For the case study and in order to reduce space, only some hardware assets have been considered in Table 12.
- Task 2: the *asset assessment* column shows the measured cybersecurity dimensions, and their impact value.
- Task 3: the highest value from the other dimensions is selected as the criticality value.

All values are shown in Table 12.

4.1.3 Activity 3: assess the damage level for the vulnerability—asset (dimension) tuples

In this activity, the damage level of the cybersecurity vulnerabilities of the assets of the organization must be determined.

In the case of the baseline, although they identify the assets and the vulnerabilities associated, however, they do not assess the damage value related to the vulnerability-asset tuple.

AVARCIBER calculates the damage value of the vulnerability-asset tuples taking into account all security dimensions, including criticality. Then, the average damage value of the vulnerability asset tuples is calculated. The damage costs associated with each identified cybersecurity vulnerability-asset tuple is established by the owner of the asset.

Table 12 Measurement of the security dimensions (including criticality) of the IESS Host platform assets

Assets identification		BASELINE/AVARCIBER			
		Asset assessment			
#	Asset	Availability	Integrity	Confidentiality	Criticality
1	Main-Frame Z10BC	10	6	7	10
2	Cartridge Unit	6	7	7	7
3	Storage Unit	10	7	6	10
4	Server HMC	6	6	7	7

Table 13 Identification of the vulnerability list of the IESS Host platform assets

Baseline	
Asset	Vulnerability
Main-Frame Z10BC	Possibility of a damaging fire Lack of flood protection Lack of training (administration staff) Inability to provide service for data links outage Not having support or manufacturer warranty Not having immediate support from the equipment manufacturer Equipment failure Lack of manufacturer's warranty (serious problems are not resolved)
Cartridge Unit	Malfunction of air conditioning equipment (without support) Possibility of a damaging fire UPS malfunction (without support) Problems in the structure of the building where the asset is located Lack of training (administration staff) Lack of contingency plans and formalized policies Theft of the password of the administration machines Issues with updates and maintenance
Storage Unit	Malfunction of air conditioning equipment (without support) UPS malfunction (without support) Unplanned growth of personnel, applications and transactionality Lack of training (administration staff) Lack of Access control at the entrance and exit Lack of contingency plans and formalized policies Theft of the password of the administration machines Lack of storage capacity and availability

For the case study and in order to reduce space, only some cybersecurity vulnerabilities are going to be considered.

The tasks to be performed in this activity are:

- Task 1: assign cybersecurity vulnerabilities to each of the assets. In this task, both the baseline (see Table 13) and AVARCIBER (see Table 14), identify the cybersecurity vulnerabilities for each asset.

Table 14 (AVARCIBER) presents a smaller number of vulnerabilities than the Baseline (see Table 12). In the case of AVARCIBER, vulnerabilities are standardized.

- Task 2: evaluate the damage level for each vulnerability-asset (dimension) tuple.
- The baseline does not consider this task.
- In AVARCIBER, the result of this task is represented by the columns *Availability (A)*, *Integrity (I)*, *Confidentiality (C)*, and *Criticality (Cr)* of Table 15.
- Task 3, 4: accumulate the damage values for each vulnerability-asset tuple, regardless of its dimension, and calculate the average damage value of the security dimensions, including criticality. The average damage value is placed in Column *Average Damage Value (ADV)* of Table 15. For the tuple 1 (Sensitivity to fire

Table 14 Identification of the Vulnerabilities related to the IESS Host Platform assets (AVARCIBER)

AVARCIBER	
Asset	Vulnerability
Main-Frame Z10BC	Sensitivity to fire and high temperatures
Main-Frame Z10BC	Location in an area susceptible to flooding
Main-Frame Z10BC	Lack of preventive and corrective support
Main-Frame Z10BC	Lack of training in asset management
Main-Frame Z10BC	Lack of technical equipment warranty
Main-Frame Z10BC	Component failure
Cartridge Unit	Lack of preventive and corrective support
Cartridge Unit	Sensitivity to fire and high temperatures
Cartridge Unit	Component failure
Cartridge Unit	Lack of training in asset management
Cartridge Unit	Lack of contingency plans
Cartridge Unit	Lack of maintenance and/or updates
Cartridge Unit	It has no backup mechanism
Storage Unit	Lack of preventive and corrective support
Storage Unit	Sensitivity to fire and high temperatures
Storage Unit	Lack of training in asset management
Storage Unit	Lack of contingency plans
Storage Unit	Component failure
Storage Unit	Lack of maintenance and/or updates

and high temperatures-Main-Frame Z10BC), ADV is calculated adding $(10+5+2+10)$ and dividing by four: ADV is equal to 6.75.

- Task 5: repeat tasks 2, 3, and 4 for all vulnerability-asset tuples.
- Task 6: assign a monetary value to each of the vulnerability-asset (dimension) tuples. Take into account that the *damage cost* is a function of both the market price of the asset, as well as the expected damage, and its replacement. The monetary value of the vulnerability-asset is entered by the organization in the column *Damage Cost* of Table 15.
- Task 7: assign a monetary cost to each asset. The organization determines this cost in case if had loss or damage, using the current market value and the cost of replacing it. The asset value is entered in column *Asset Cost* of Table 15.

4.1.4 Activity 4: identify cybersecurity threats

The baseline does not consider this activity.

AVARCIBER identifies threats that can materialize the cybersecurity vulnerabilities of the assets. The threats are grouped by vulnerabilities and assets, the impact of the

Table 15 Asset Cost for each asset, and average damage value and damage cost for each vulnerability-asset tuple related to the IESS Host Platform

AVARCIBER									
#	Vulnerabilities	Asset	Asset cost	A	I	C	Cr	ADV	Damage cost
1	Sensitivity to fire and high temperatures	Main-Frame Z10BC	300,000€	10	5	2	10	6.75	300,000€
2	Location in an area susceptible to flooding	Main-Frame Z10BC		10	5	2	10	6.75	300,000€
3	Lack of preventive and corrective support	Main-Frame Z10BC		5	5	5	10	6.25	120,000€
4	Lack of training in asset management	Main-Frame Z10BC		5	5	5	10	6.25	150,000€
5	Lack of technical equipment warranty	Main-Frame Z10BC		10	10	5	10	8.75	150,000€
6	Component failure	Main-Frame Z10BC		10	5	5	10	7.5	90,000€
7	Lack of preventive and corrective support	Cartridge Unit	10,000€	5	5	2	7	4.75	5000€
8	Sensitivity to fire and high temperatures	Cartridge Unit		10	10	1	7	7	10,000€
9	Component failure	Cartridge Unit		10	10	2	7	7.25	5000€
10	Lack of training in asset management	Cartridge Unit		5	5	2	7	4.75	3000€
11	Lack of contingency plans	Cartridge Unit		10	10	5	7	8	10,000€
12	Lack of maintenance and/or updates	Cartridge Unit		10	10	5	7	8	10,000€
13	It has no backup mechanism	Cartridge Unit	500,000€	10	10	2	7	7.25	10,000€
14	Lack of preventive and corrective support	Storage Unit		10	10	2	10	8	250,000€
15	Sensitivity to fire and high temperatures	Storage Unit		10	10	2	10	8	500,000€
16	Lack of training in asset management	Storage Unit		10	5	5	10	7.5	500,000€
17	Lack of contingency plans	Storage Unit		10	5	5	10	7.5	500,000€
18	Component failure	Storage Unit		10	10	5	10	8.75	200,000€
19	Lack of maintenance and/or updates	Storage Unit		10	10	5	10	8.75	500,000€

Table 16 Threats and vulnerabilities with damage value and damage cost related to the IESS Host Platform

AVARCIBER					
#	Threat	Vulnerability	Asset	Average damage value	Damage cost (€)
1	Fire	Sensitivity to fire and high temperatures	Main-Frame Z10BC	6.75	300,000€
2	Flood	Location in an area susceptible to flooding	Main-Frame Z10BC	6.75	300,000€
3	Failure or interruption of main supply	Lack of preventive and corrective support	Main-Frame Z10BC	6.25	120,000€
4	Misuse or administration of devices and systems	Lack of training in asset management	Main-Frame Z10BC	6.25	150,000€
5	Device or system failure	Lack of technical equipment warranty	Main-Frame Z10BC	8.75	150,000€
6	Device or system failure	Component failure	Main-Frame Z10BC	7.5	90,000€
7	Unfavorable climatic conditions	Lack of preventive and corrective support	Cartridge Unit	4,75	5000€
8	Fire	Sensitivity to fire and high temperatures	Cartridge Unit	7	10,000€
9	Device or system failure	Component failure	Cartridge Unit	7.25	5000€
10	Misuse or administration of devices and systems	Lack of training in asset management	Cartridge Unit	4.75	3000€
11	Device or system failure	Lack of contingency plans	Cartridge Unit	8	10,000€
12	Device or system failure	Lack of maintenance and/or updates	Cartridge Unit	8	10,000€
13	Inadequate design and planning or improper adaptation	It has no backup mechanism	Cartridge Unit	7.25	10,000€
14	Unfavourable climatic conditions	Lack of preventive and corrective support	Storage Unit	8	250,000€
15	Fire	Sensitivity to fire and high temperatures	Storage Unit	8	500,000€
16	Misuse or administration of devices and systems	Lack of training in asset management	Storage Unit	7.5	500,000€
17	Device or system failure	Lack of contingency plans	Storage Unit	7.5	500,000€
18	Device or system failure	Component failure	Storage Unit	8.75	200,000€
19	Device or system failure	Lack of maintenance and/or updates	Storage Unit	8.75	500,000€

threat is averaged, and the cost associated with the threat is added.

For the case study and in order to reduce space, only some cybersecurity threats are going to be considered.

The tasks to be performed in this activity are:

- Task 1: identify all cybersecurity threats from the taxonomy threats (Activity 1—Task 3) previously defined. Threats are chosen for each vulnerability as shown in column *Threat* of Table 16.
- Task 2: determine the vulnerabilities for each cybersecurity threat. Threats are associated with each

vulnerability and asset, as indicated in columns *Threat*, *Vulnerability* and *Asset* of Table 16.

- Task 3: recover the values of the average damage of the vulnerability-asset tuple (column *ADV* in Table 15) and damage cost (in Table 15), and assign them to the threat-vulnerability-asset tuples as shown in Table 16.
- Task 4: Threats are grouped, and the damage value of the threat is calculated. In Table 17 and in the case of the *fire* threat: 1) the Threat Damage Value is obtained taken into account the information from Table 16 (rows labelled as 1, 8 and 15): $(6.75+7+8)/3 = 7.25$; 2) the Damage Cost is also obtained from Table 16: $300,000€ + 10,000€ + 500,000€ = 810,000€$.

Table 17 Threat damage value and cost for the IESS Host platform

Threats	Threat damage value	Threat damage cost
Flood	6.75	300,000€
Unfavorable climatic conditions	6.38	255,000€
Inadequate design and planning or improper adaptation	7.25	10,000€
Device or system failure	8.13	290,000€
Device or system failure	8.75	150,000€
Device or system failure	8.38	510,000€
Device or system failure	7.75	510,000€
Failure or interruption of main supply	7.25	5,000€
Failure or interruption of main supply	6.25	120,000€
Fire	7.25	810,000€
Misuse or administration of devices and systems	6.17	653,000€

Table 18 Risk related to the IESS Host Platform by asset

ASSET: Main-Frame Z10BC Criticality: 3

VULNERABILITIES Description	THREATS Description	DIMENSION					
		A (%)	I (%)	C (%)	IM	FR	RISK
Possibility of fire	Damage caused by fire	100	50	20	3	0	0.3
Lack of flood protection	Water damage	100	50	20	3	0	0.3
Structural problems of the building where the asset is located	Damage caused by Natural Disasters (Earthquakes)	100	100	20	3	0	0.3
UPS without technical support	Damage caused by power failure	50	50	50	1.5	0	0.15
Malfunction of air conditioning equipment (without support)	Damage caused by inadequate temperature and humidity conditions	50	50	20	1.5	1	1.5
Lack of training (administration staff)	Possibility of user errors in the administration, configuration and monitoring of the equipment	50	50	50	1.5	0	0.15
Inability to provide service for issues in data links	Possibility of interrupting data link services	100	50	50	3	0	0.3
No support and manufacturer warranty	Lack of support and manufacturer's warranty on the hardware in which the solution is installed	100	100	50	3	2	6
Not having support from the equipment manufacturer at the moment	Lack of support and equipment update	50	50	20	1.5	2	3
Equipment failure	Loss of connectivity service with peripheral elements of the platform	100	50	50	3	1	3

4.1.5 Activity 5: measure the risk

In the baseline, a vulnerability threat assignment was made and only the impact is calculated based on the dimensions of the asset (availability, integrity, confidentiality) for each threat (in terms of percentage). The risk is calculated based on the impact (IM) of the threat and the frequency (FR) of occurrence of the threat, as it can be seen in Table 18.

In this activity, AVARCIBER groups the threats, and in order to calculate the total threat damage value, the average is calculated. In the same way, the total threat damage cost is calculated adding the threat damage costs involved.

These values are then analyzed for each threat, only to identify the frequency of occurrence, and calculate the risk of the threat, as shown in Table 19.

The tasks to be performed in this activity are:

- Task 1: retrieve the rounded value of the Threat Damage Value (the impact) and the Damage Cost of the Threat, as shown in the Table 19.
- Task 2: assign the probability of occurrence of the threat, as it can be seen in column Frequency of Table 19.
- Task 3: calculate the exposure to cybersecurity risk. The risk is calculated according to the data defined in

Table 19 Risks for the IESS Host Platform

Threats	Threat Damage Value	Frequency	Risk	Total Threat Damage Cost
Flood	7	B	3	300,000 €
Unfavorable climatic conditions	6	B	3	255,000 €
Inadequate design and planning or improper adaptation	7	MA	9	10,000 €
Device or system failure	8	A	8	1,460,000 €
Failure or interruption of main supply	7	M	5	125,000 €
Fire	7	B	3	810,000 €
Misuse or administration of devices and systems	6	B	3	653,000 €

Table 20 Safeguards per asset in the Baseline

Asset	Vulnerability	Threats	Safeguards
Main-Frame Z10BC	No support and manufacturer warranty	Lack of support and manufacturer's warranty on the hardware in which the solution is installed	Review and validate the feasibility of fixing existing damages and/or manage technical support and maintenance
Cartridge Unit	Problems with updates and maintenance due to expired technological validity Not have backup media	Damage caused by lack of maintenance (physical and logical) and operating system update No continuity with the host closure project	Implement a backup management solution (service) that allows the use of cartridges and manage technical support and periodic maintenance on that equipment
Storage Unit	Problems with updates and maintenance due to expired technological validity	Damage caused by lack of maintenance (physical and logical) and operating system update	Have technical support and periodic maintenance that guarantees the current storage of applications, data and operating system of the Host

Table 9, as it can be seen in the *Risk* column of Table 19.

The information to be highlighted in this table is the possibility of identifying the cost of a threat to the organization independently of the risk occurrence.

4.1.6 Activity 6: perform countermeasures

In the baseline, a countermeasure (safeguard) is identified for each asset, to solve the identified cybersecurity threats and vulnerabilities. Thus, a countermeasure is obtained for each asset, as shown in Table 20.

In this activity, AVARCIBER determines the identification of a countermeasure for each cybersecurity vulnerability that has been identified in assets. Thus, it is possible to implement mechanisms that help mitigate the identified risks. The prioritization of countermeasures to be implemented is directly related to the risks and the value associated with the identified threats (total threat damage cost). Countermeasures are shown in Table 21.

4.2 Results of comparing the baseline and AVARCIBER

Next, the results when comparing the baseline and the application of the AVARCIBER framework to the Host platform of the IESS are presented.

- The conceptual model for the cybersecurity risk management of the baseline is based on threat management and AVARCIBER on vulnerabilities. Therefore, AVARCIBER is generating greater control in the identification and mitigation of cybersecurity risks.
- The parameters of impacts and damages of the baseline are qualitative and have an insufficient number of defined levels. The lack of levels was the reason why the impacts could not be obtained in a more precise way. In AVARCIBER, the levels are quantitative, and also new ones have been incorporated. These reasons are what allows AVARCIBER to achieve greater accuracy when assigning values.
- The baseline does not handle taxonomies of assets, cybersecurity vulnerabilities and threats, generating errors when entering them manually. With the

Table 21 Countermeasures for the vulnerabilities of the IESS Host in AVARCIBER

VULNERABILITY	COUNTERMEASURE
Location in an area susceptible to flooding	Physical improvement of facilities, adequate drainage
Lack of preventive and corrective support	Support and maintenance contracts in force
It has no backup mechanism	Have a backup device for the asset
Component Failure	Support and maintenance contracts in force
Lack of technical equipment warranty	Warranty contract in force
Lack of maintenance and/or updates	Maintenance contracts and current updates
Lack of contingency plans	Generate contingency plan per asset
Lack of preventive and corrective support	Support and maintenance contracts in force
Sensitivity to fire and high temperatures	Proper password management process
Lack of training in asset management	Continuous training in asset management

taxonomies defined in AVARCIBER, the assignment of the values was facilitated without incurring in duplication or syntax errors.

- The baseline does not assess the costs of the vulnerabilities associated with the assets, while AVARCIBER does. This allows to add the total value of all common vulnerabilities per threat, with a total cost assigned to each threat in order to identify the most expensive threat to the organization.
- The risk matrix in the baseline shows the risk values according to the impact of threats. In AVARCIBER, the cost of the associated risk is included, which generates information to identify the critical risks.
- Countermeasures at the baseline are assigned per asset. In AVARCIBER, the countermeasures are identified by vulnerabilities that may arise in several assets, allowing greater coverage with a single countermeasure.

5 Conclusions

This paper has presented a conceptual model for cybersecurity risk management. In addition, a framework has been presented (AVARCIBER) to manage cybersecurity risks based on the conceptual model. The framework has been applied in a case study to be validated. The following can be concluded:

- The conceptual model includes the assessment of the cybersecurity vulnerabilities of assets, which has allowed us to measure not only the impact of the vulnerability, but also the cost in case of vulnerability.
- The elements of the conceptual model and the defined framework have been complemented, generating results that respond to the needs of the organization such as establishing countermeasures based on a quantitative risk assessment. This improvement allows the organization not only to manage the risks for its impact, but also because of the cost to the organization.

- The use of taxonomies generated from assets, cybersecurity vulnerabilities and threats have allowed better management. A problem that has been avoided is the duplication of vulnerabilities and threats because there was no standard.
- The identification of asset costs and assessment of asset vulnerabilities has helped to quantitatively identify the impact of threats in materializing vulnerabilities. In this way, the understanding of the economic damage to which they are exposed has been improved.
- It has generated greater visibility of the critical threats and of the most recurrent vulnerabilities, complemented with the assessment of each one of them, generating detailed and quantifiable information.
- The identified countermeasures were associated with the identified vulnerabilities to solve them, generating a more effective response because the countermeasures solve the vulnerabilities of all the assets in which they are present.

As a conclusion, we can indicate that the measurement of risks using the suggested conceptual model and the AVARCIBER framework has allowed us to have a better vision of the relationships that the elements of cybersecurity risk management may have. The quantification of assets and vulnerabilities allows improving decision-making based on the criticality of the risks and countermeasures that must be applied.

The next step in this research work is to implement a software system that allows the automation of this conceptual model, based on the AVARCIBER framework.

References

1. Mendoza, M.A.: ¿Ciberseguridad o seguridad de la información? Aclarando la diferencia. <https://www.welivesecurity.com/la-es/2015/06/16/ciberseguridad-seguridad-informacion-diferencia/> (2015)

2. Donaldson, S.E., Siegel, S.G., Williams, C.K., Aslam, A.: Enterprise Cybersecurity: How to Build a Successful Cyberdefense Program Against Advanced Threats, pp. 24–25. Apress, New York (2015)
3. ESET: TENDENCIAS 2019: Privacidad e intrusión en la aldea global. www.eset.com (2019)
4. OEA: Ciberseguridad marco nist. <http://www.oas.org/es/> (2019)
5. Truta, F.: The top five cybersecurity incidents of 2018. <https://businessinsights.bitdefender.com/the-five-key-security-incidents-of-2018> (2018)
6. Rea-Guaman, A.M., Sánchez-García, I.D., San Feliu, T., Calvo-Manzano, J.A.: Maturity Models in Cybersecurity: a systematic review. In: 12th Conferencia Ibérica de Sistemas y Tecnologías de Información (CISTI'17). Lisbon (2017)
7. Department of Energy: Cybersecurity Capability Maturity Model (C2M2): Version 1.1. Technical report, Department of Homeland Security (2014)
8. US Department of Homeland Security: Cybersecurity Capability Maturity Model: Version 1.0. White paper, Department of Homeland Security (2014)
9. SSE Project Team: System Security Engineering Capability Maturity Model (SSE-CMM): Model Description Document Version 3.0. Technical report, SSE-CMM (2003)
10. White, G.B.: The community cyber security maturity model. In: IEEE International Conference on Technologies for Homeland Security, pp. 173–178. IEEE Press, Wakefield (2011)
11. ISO 38500: Corporate Governance of Information Technology. <http://www.iso.org> (2015)
12. Awan, M.S.K., Burnap, P., Rana, O.: Identifying cyber risk hotspots: a framework for measuring temporal variance in computer network risk. *Comput. Secur.* **57**, 31–46 (2016). <https://doi.org/10.1016/j.cose.2015.11.00>
13. Delmee, F.: The Structure of a Cyber Risk a Scenario Based Approach in Cyber Risk. Utrecht University Repository, Utrecht (2016)
14. Cebula, J.J., Young, L.R.: A Taxonomy of Operational Cyber Security Risks, pp. 1–47. Software Engineering Institute, Carnegie-Mellon University, Pittsburgh (2010). <https://doi.org/10.1007/978-1-4419-7133-3>
15. NIST: Guide for conducting risk assessments. NIST Special Publication, Gaithersburg (2012). <https://doi.org/10.6028/NIST.SP.800-30r1>
16. Standard, I.: INTERNATIONAL STANDARD ISO/IEC 27005 Information security risk management (2011)
17. Dobson, I., Hietala, J.: Risk Management: The Open Group Guide. 118. <http://books.google.com/books?id=p4f8jUT2wgUC&pgis=1> (2011)
18. Initiative, J.T.F.T.: Managing Information Security Risk. Nist Special Publication, Gaithersburg (2011). <https://doi.org/10.1007/s10845-012-0683-0>
19. Caralli, R., Stevens, J.F., Young, L.R., Wilson, W.R.: Introducing OCTAVE allegro: improving the information security risk assessment process. Young (May), pp. 1–113 (2007)
20. Singh, V.: Revisiting security ontologies. *Int. J. Comput. Sci. Issues* **11**(6), 150–159 (2014)
21. Singhal, A., Wijesekera, D.: Ontologies for modeling enterprise level security metrics. In: Proceedings of the sixth annual workshop on cyber security and information intelligence research—CSIIRW '10, 1. <https://doi.org/10.1145/1852666.1852731> (2010)
22. Singhal, A., Singapogu, S.: Security Ontologies for Modeling Enterprise Level Risk Assessment. NIST Special Publication, Gaithersburg (2012)
23. Goodwin, C., Nicholas, J.P., Bryant, J., Ciglic, K., Kleiner, A., Kutterer, C., Sullivan, K., et al.: A framework for cybersecurity information sharing and risk reduction, pp. 1–24. http://download.microsoft.com/download/8/0/1/801358EC-2A0A-4675-A2E7-96C2E7B93E73/Framework_for_Cybersecurity_Info_Sharing.pdf (2015)
24. Rea-Guaman, A.M., San, Feliu T., Calvo-Manzano, J.A., Sanchez-Garcia, I.D.: Systematic review: cybersecurity risk taxonomy. In: Mejia, J., Muñoz, M., Rocha, Á., Quiñonez, Y., Calvo-Manzano, J. (eds.) Trends and Applications in Software Engineering. CIMPS 2017. Advances in Intelligent Systems and Computing, vol. 688. Springer, Cham (2018)
25. Baltar, F., Brunet, I.: Social research 2.0: virtual snowball sampling method using Facebook. *Internet Res.* **22**(1), 57–74 (2012)
26. Buchanan, L., Larkin, M., D'Amico, A.: Mission assurance proof-of-concept: mapping dependencies among cyber assets, missions, and users. In: 2012 IEEE International Conference on Technologies for Homeland Security, HST 2012, pp. 298–304. <https://doi.org/10.1109/THS.2012.6459865> (2012)
27. Shamala, P., Ahmad, R.: A proposed taxonomy of assets for information security risk assessment (ISRA). In: 2014 4th World Congress on Information and Communication Technologies, WICT 2014, pp. 29–33. <https://doi.org/10.1109/WICT.2014.7077297> (2014)
28. Wielki, J.: A Framework of the Impact of Cyberspace on Contemporary Organizations. IEEE, Piscataway (2006)
29. Yazid, A.I.S., Faizal, M.A., Rabiah, A., Shahrin, S., Solahuddin, S.: Enhancement of asset value classification for mobile devices. In: Proceedings 2012 International Conference on Cyber Security, Cyber Warfare and Digital Forensic, CyberSec 2012, pp. 106–110. <https://doi.org/10.1109/CyberSec.2012.6246097> (2012)
30. Farooq, A., Kakakhel, S.R.U., Virtanen, S., Isoaho, J.: A taxonomy of perceived information security and privacy threats among IT security students. In: 2015 10th International Conference for Internet Technology and Secured Transactions, ICITST 2015, pp. 280–286. <https://doi.org/10.1109/ICITST.2015.7412106> (2016)
31. Yu, Z., Thomborson, C., Wang, C., Fu, J., Wang, J.: A security model for VoIP steganography. In: 1st International Conference on Multimedia Information Networking and Security, MINES 2009, vol. 1, pp. 35–40. <https://doi.org/10.1109/MINES.2009.227> (2009)
32. Razzaq, A., Anwar, Z., Ahmad, H.F., Latif, K., Munir, F.: Ontology for attack detection: an intelligent approach to web application security. *Comput. Secur.* **45**, 124–146 (2014). <https://doi.org/10.1016/j.cose.2014.05.005>
33. Shameli-Sendi, A., Aghababaei-Barzegar, R., Cheriet, M.: Taxonomy of information security risk assessment (ISRA). *Comput. Secur.* **57**, 14–30 (2016). <https://doi.org/10.1016/j.cose.2015.11.001>
34. Bazaz, A., Arthur, J.D.: Towards a taxonomy of vulnerabilities. In: Proceedings of the Annual Hawaii International Conference on System Sciences, (c), pp. 1–10. <https://doi.org/10.1109/HICSS.2007.566> (2007)
35. Zhao, Z., Dai, Y.: A new method of vulnerability taxonomy based on information security attributes. In: 2012 IEEE 12th International Conference on Computer and Information Technology, pp. 739–741. <https://doi.org/10.1109/CIT.2012.152> (2012)
36. Ahmad, N.H., Aljunid, S.A., & Manan, J.L.A.: Understanding vulnerabilities by refining taxonomy. In: Proceedings of the 2011 7th International Conference on Information Assurance and Security, IAS 2011, pp. 25–29. <https://doi.org/10.1109/ISIAS.2011.6122789> (2011)
37. Igre, V.M., Williams, R.D.: Taxonomies of attacks and vulnerabilities in computer systems. *IEEE Commun. Surv. Tutor.* **10**(1), 6–19 (2008). <https://doi.org/10.1109/COMST.2008.4483667>

38. Marinos, L.: Threat taxonomy: a tool for structuring threat information. Initial report. (January), pp. 1–24. <https://www.enisa.europa.eu/topics/threat-risk-management/threats-and-trends/enisa-threat-landscape/etl2015/enisa-threat-taxonomy-a-tool-for-structuring-threat-information> (2016)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.



Angel Marcelo Rea-Guaman is a Ph.D. student of the Polytechnic University of Madrid fourth year, where he is investigating the Maturity in the Identification and Evaluation of Risks in Cybersecurity, he is currently conducting the experimentation of his doctoral work in companies in Ecuador such as IESS and Petroecuador. He has written four articles related to the subject. He currently works at Petroecuador, as Head of Infrastructure Operations.



Jezreel Mejía has a Ph.D. in Computer Languages, Informatics Systems and Software Engineering from the Polytechnic University of Madrid. He is actually a Software Engineering researcher at CIMAT in México. He is member of the National Researchers System of Mexico in Level I. He is a member of scientific committee of several international conferences. He has participated in the Spanish Translation of CMMI-Dev model v1.2 and v1.3. His

main research is focused on multi-model environments, project management, acquisition and outsourcing process, solicitation and supplier agreement development and agile methodologies. He has published several technical papers on acquisition, process improvement, project management, TSPI, CMMI and multi-model environments.



Tomas San Feliu holds a Ph.D. in Computer Science. He is an associate professor in the Computer Science School at the Universidad Politécnica de Madrid. He is teaching in the area of Software Engineering, specifically in the domain of software process management and improvement. He has participated in more than 20 research projects (European and Spanish Public Administration). He is an author of books related to software process improve-

ment and software engineering topics also. He has participated in the Spanish Translation of CMMI-Dev model v1.2 and v1.3. His main research is focused on acquisition process, risk management, project management, software metrics, and cybersecurity maturity models. He has published several technical papers on acquisition, process improvement, project management, TSPI, CMMI and multi-model environments.



Jose A. Calvo-Manzano holds a Ph.D. in Computer Science. He is an associate professor in the “Escuela Técnica Superior de Ingenieros Informáticos” (Computer Engineering School) at the “Universidad Politécnica de Madrid” (Technical University of Madrid) where he teaches in the area of Software Engineering, specifically in the domain of Software Process Management and Improvement. He has participated in more than 20 research projects (European,

Spanish Public Administration as well as with private enterprises). He is co-author of more than 80 international journal papers and more than 100 conference papers. He is co-author of more than 15 books about software process improvement and software engineering topics as well. He was the Head of the “Research Chair for Software Process Improvement for Spain and the Latin American Region”, where he was a member of the team that translated CMMI-DEV v1.2 and v1.3 into Spanish. He also holds the ITIL® v2 and v3 Foundation, and CMDB Certifications.